

# Verbindliche Vorgaben in der IT-Infrastruktur: Eine wissenschaftliche Analyse von Verfügbarkeit, Sicherheit und Aufbewahrung im Datenhaltungskonzept

Autor: Mevluet Polat

## Abstract

Die fortschreitende Digitalisierung zwingt moderne Organisationen dazu, ihre IT-Infrastrukturen mit einem Höchstmass an Resilienz, Sicherheit und rechtlicher Konformität zu gestalten. Der vorliegende Artikel analysiert auf Basis aktueller konzeptioneller Vorgaben die essenziellen Säulen eines modernen Datenhaltungskonzepts. Im Fokus stehen dabei die verbindlichen Vorgaben zur Systemverfügbarkeit, die durch spezifische Verfügbarkeitsklassen, RTO-Metriken (Recovery Time Objective) und Service Level Agreements (SLAs) operationalisiert werden. Im zweiten Teil der Untersuchung werden die zwingenden Sicherheits- und Aufbewahrungsvorgaben beleuchtet, welche von Verschlüsselungsstandards über strenge Aufbewahrungsfristen bis hin zu geographischen Datenlokalisierungsstrategien in der Schweiz reichen. Durch die theoretische Fundierung und die Anreicherung mit praxisnahen Beispielen wird ein ganzheitliches Rahmenwerk präsentiert, das als Leitfaden für das Design und den Betrieb kritischer IT-Systeme dient.

## 1. Einleitung

In der heutigen von Daten getriebenen Wirtschaft ist der reibungslose Betrieb von IT-Systemen nicht mehr nur ein operativer Vorteil, sondern eine geschäftskritische Notwendigkeit. Ein Systemausfall oder der Verlust von sensiblen Daten kann für Unternehmen existenzbedrohende finanzielle Schäden sowie einen massiven Reputationsverlust nach sich ziehen. Um diesen Risiken proaktiv zu begegnen, bedarf es eines stringenten Datenhaltungskonzepts, das verbindliche Vorgaben für die Verfügbarkeit, die Sicherheit und die Aufbewahrung von Daten definiert.

Diese Vorgaben dürfen nicht als blosse Empfehlungen verstanden werden, sondern müssen als harte, messbare und einklagbare Parameter in das IT-Service-Management (ITSM) und das Information Security Management System (ISMS) einer Organisation integriert werden. Der folgende Artikel systematisiert diese Vorgaben in zwei Hauptkategorien: Einerseits die Sicherstellung der Verfügbarkeit durch technologische und organisatorische Redundanzen,

andererseits die Gewährleistung von Sicherheit und Compliance durch strikte kryptographische, prozessuale und geographische Richtlinien. Zur besseren Nachvollziehbarkeit werden die abstrakten Konzepte durchgehend mit Beispielen aus der betrieblichen Praxis, insbesondere unter Berücksichtigung des Schweizer Geschäftsumfelds, illustriert.

## 2. Verbindliche Vorgaben – Verfügbarkeit

Die Verfügbarkeit (Availability) ist eines der drei Kernziele der Informationssicherheit (neben Vertraulichkeit und Integrität). Sie definiert, inwiefern IT-Dienste, Applikationen und die zugrundeliegenden Daten genau dann abrufbar und nutzbar sind, wenn sie vom Anwender oder einem anderen System benötigt werden.

### 2.1 Verfügbarkeitsklassen definieren (Folie 14)

Um Investitionen in die IT-Infrastruktur wirtschaftlich sinnvoll zu steuern, verbietet es sich, alle Systeme über denselben Kamm zu scheren. Ein "One-Size-Fits-All"-Ansatz würde entweder zu astronomischen Kosten führen (wenn alles hochverfügbar gemacht wird) oder inakzeptable Risiken bergen (wenn kritische Systeme unterversorgt sind). Die Lösung liegt in der strengen Kategorisierung von Systemen nach ihrer tolerierten Ausfallzeit und den daraus resultierenden Backup- und Wiederherstellungsanforderungen.

Das Konzept definiert hierbei vier klar abgegrenzte Klassen:

- **Klasse 1 (Sehr hohe Kritikalität):** Ein Ausfall ist für das Unternehmen absolut nicht tolerierbar. Die Recovery Time Objective (RTO) – also die Zeit, bis das System nach einem Ausfall wieder laufen muss – liegt bei unter einer Stunde. Dies erfordert ein sogenanntes Hot-Standby-System, welches sofort und meist automatisiert übernehmen kann.
- **Klasse 2 (Wichtige Systeme):** Hier besteht eine begrenzte Toleranz für Ausfälle. Die RTO wird in wenigen Stunden gemessen. Es bedarf eines Warm-Standby-Systems oder zumindest einer extrem schnellen Restore-Lösung (Wiederherstellungslösung).
- **Klasse 3 (Moderate Kritikalität):** Ein Ausfall von bis zu einem Tag (RTO) ist für den Geschäftsbetrieb verkraftbar. Ein reguläres, tägliches Backup (meist über Nacht) ist hier völlig ausreichend.
- **Klasse 4 (Geringe Kritikalität):** Systeme, deren Ausfall mehrere Tage andauern darf, ohne massiven Schaden anzurichten. Eine wöchentliche Sicherung genügt den Anforderungen.

#### Praxisbeispiel:

Stellen wir uns ein grosses Schweizer Kantonsspital vor.

- Das lebenserhaltende Patientenüberwachungssystem auf der Intensivstation fällt zwingend in **Klasse 1**. Fällt es aus, geht es um Menschenleben. Es muss in Sekunden oder wenigen Minuten ( $RTO < 1h$ ) von einem redundanten System übernommen werden.

- Das elektronische Patientendossier (EPD) oder das Labor-Informationssystem fällt in **Klasse 2**. Ein Ausfall für zwei Stunden ist höchst ärgerlich und erfordert organisatorische Workarounds (z.B. Papiernotizen), gefährdet aber nicht unmittelbar das Leben.
- Das interne Intranet für Mitarbeiter-Newslettern fällt in **Klasse 3**. Wenn es einen Tag nicht verfügbar ist, arbeitet das Spital problemlos weiter.
- Das Archiv der Speisepläne der Spitalkantine aus dem Vorjahr fällt in **Klasse 4**. Hier reicht ein wöchentliches Backup völlig aus.

## 2.2 Vorgaben für hochverfügbare Systeme (Folie 15)

Systeme der Klasse 1 (und teilweise Klasse 2) erfordern ein spezialisiertes Architekturdesign, das sogenannte Hochverfügbarkeits-Design (High Availability - HA). Die technischen Grundvoraussetzungen hierfür sind strikt und unumstösslich:

- **Redundanz:** Jede einzelne Komponente muss mehrfach (mindestens N+1) vorhanden sein. Dies betrifft nicht nur Server, sondern zwingend auch Hardware-Switches, Netzwerkverbindungen (zwei unterschiedliche Provider) und die Stromversorgung (A/B-Feeds, USV, Diesel-Generatoren).
- **Replikation:** Daten müssen in Echtzeit (synchron) auf ein Standby-System gespiegelt werden. Nur so ist sichergestellt, dass bei einem plötzlichen Ausfall der primären Datenbank keine (oder nur absolut minimale) Datenverluste, gemessen als Recovery Point Objective (RPO), entstehen.
- **Clustering:** Mehrere Server (Knoten/Nodes) werden zu einem logischen System zusammengeschlossen. Fällt ein Knoten aus, erkennt der Cluster dies (oft über sogenannte "Heartbeats") und die Arbeitslast wird vollautomatisch und ohne Unterbrechung für den Endnutzer auf einen anderen Knoten verschoben.
- **Monitoring:** Ein permanentes, automatisiertes Überwachungssystem ist zwingend. Es darf nicht gewartet werden, bis ein Nutzer anruft und einen Fehler meldet. Das System muss bei kleinsten Anomalien (z.B. ungewöhnlich hohe CPU-Last, drohender Speicherengpass) sofort proaktiv Alarm schlagen (Paging, SMS an Pikett-Dienst).
- **Wartungsfenster:** Hochverfügbarkeit bedeutet auch "Zero Downtime" bei geplanten Eingriffen. Patches, Updates und Hardware-Tausche müssen im laufenden Betrieb ("Hot Swap" oder durch temporäres Verschieben der Last im Cluster) durchgeführt werden können.

### Praxisbeispiel:

Ein Schweizer E-Commerce-Unternehmen am "Black Friday". Die Webserver laufen in einem **Cluster**. Wenn Server A wegen Überlastung abstürzt, leitet der Load Balancer den Traffic sofort auf Server B und C um. Die Datenbanken nutzen **synchrone Replikation**: Wenn ein Kunde auf "Kaufen" klickt, wird die Transaktion gleichzeitig im primären Rechenzentrum in Zürich und im sekundären Rechenzentrum in Bern gespeichert. Die Stromversorgung in beiden Rechenzentren ist komplett **redundant** (A/B-Schienen). Ein Ausfall einer einzigen Komponente

führt zu keinerlei spürbarem Unterbruch für den Kunden.

## 2.3 RTO-Vorgaben im Konzept (Folie 16)

Die Festlegung der Recovery Time Objective (RTO) ist keine rein technische, sondern primär eine geschäftliche Entscheidung (Business Impact Analysis). Das Datenhaltungskonzept fordert hier verbindliche Werte.

- **RTO-Festlegung:** Für wirklich jede Applikation und jeden relevanten Datensatz muss ein konkreter Wert definiert sein. "So schnell wie möglich" ist keine RTO. Ein Wert wie "4 Stunden" ist verbindlich.
- **Technologieauswahl:** Die RTO diktiert die Technik. Eine RTO von 15 Minuten lässt sich nicht mit dem Wiederherstellen von Magnetbändern aus einem externen Tresor erreichen. Hier müssen Flash-Speicher-Snapshots oder aktive Replikationen genutzt werden.
- **Ressourcenplanung:** Es gilt die Faustregel: Eine Halbierung der RTO führt oft zu einer Verdoppelung der Infrastrukturkosten. Kurze RTOs erfordern teure, dedizierte Ausweichkapazitäten und modernste Backup-Appliances.
- **Testnachweis:** Ein RTO-Wert auf dem Papier ist wertlos, wenn er in der Krise nicht eingehalten wird. Die Vorgaben verlangen regelmässige, dokumentierte Restore-Tests. Nur was getestet wurde, funktioniert nachweislich.
- **Anpassung:** Wenn ein Restore-Test ergibt, dass die Wiederherstellung der Datenbank statt der geforderten 4 Stunden ganze 12 Stunden dauert, muss zwingend und sofort gehandelt werden (Prozessoptimierung oder Technologieaustausch).

### Praxisbeispiel:

Ein Treuhandbüro wurde Opfer eines Ransomware-Angriffs (Verschlüsselungstrojaner). Alle Systeme stehen still. Gemäss Konzept liegt die RTO für die zentrale Buchhaltungssoftware bei 8 Stunden. Die IT-Abteilung beginnt den Restore aus dem unveränderlichen (immutable) Backup der vergangenen Nacht. Weil dieser Prozess im Vorfeld **getestet und dokumentiert** wurde (Testnachweis), weiss das Team genau, in welcher Reihenfolge die Server gestartet werden müssen. Die **Technologieauswahl** (schnelle Disk-basierte Backups) stellt sicher, dass die Daten rechtzeitig zurückgespielt werden und das Büro nach genau 7 Stunden wieder voll arbeitsfähig ist.

## 2.4 SLA und Verfügbarkeitsvorgaben (Folie 17)

Die Brücke zwischen den technischen Realitäten und den geschäftlichen Erwartungen wird durch Service Level Agreements (SLAs) geschlagen. Ein SLA ist ein Vertrag zwischen dem IT-Dienstleister (intern oder extern) und dem Kunden (Fachbereich).

- **SLA-Definition:** Die Verfügbarkeitsziele werden verbindlich festgehalten, zumeist in Prozenten (z.B. 99,9 % Verfügbarkeit pro Jahr, was einer erlaubten Ausfallzeit von ca. 8,7 Stunden entspricht).

- **Messung & Reporting:** Die Verfügbarkeit darf nicht gefühlt, sondern muss kontinuierlich und objektiv durch Monitoring-Tools gemessen werden. Die Ergebnisse fliessen in regelmässige Verfügbarkeitsberichte (Reports) an die Unternehmensleitung.
- **Eskalation:** Fällt die Verfügbarkeit unter den definierten Wert, treten vertraglich vereinbarte Eskalationsstufen in Kraft. Dies reicht von der Einberufung einer Taskforce bis hin zu finanziellen Strafen (Malus-Zahlungen) bei externen Dienstleistern.
- **Vertragsgrundlage:** Die internen Konzepte bilden die absolute Basis. Die IT darf mit einem externen Cloud-Anbieter keine Verträge abschliessen, die schlechtere Verfügbarkeitswerte aufweisen, als das interne Datenhaltungskonzept für die jeweilige Applikation vorschreibt.

#### Praxisbeispiel:

Eine Schweizer Bank lagert den Betrieb ihrer Geldautomaten-Infrastruktur an einen IT-Dienstleister aus. Das interne Konzept fordert für diese Klasse-1-Systeme eine Verfügbarkeit von 99,99 % (ca. 52 Minuten Ausfallzeit pro Jahr). Dieses Ziel wird als **SLA** in den Vertrag aufgenommen. Das **Monitoring** stellt im Mai fest, dass die Systeme bereits 40 Minuten ausgefallen waren. Es erfolgt sofort eine **Eskalation** an das Management, und der Dienstleister muss präventive Massnahmen ergreifen, da bei Überschreiten der 52 Minuten hohe Vertragsstrafen fällig werden. Das monatliche **Reporting** macht diese kritische Situation für den Vorstand transparent.

## 3. Verbindliche Vorgaben – Sicherheit und Aufbewahrung

Während der erste Teil des Konzepts sicherstellt, dass die Daten vorhanden und erreichbar sind, regelt die Hauptkategorie 5 den fundamentalen Schutz dieser Daten vor unberechtigtem Zugriff sowie deren gesetzeskonforme langfristige Archivierung.

### 3.1 Sicherheitsvorgaben im Konzept (Folie 18)

Backup-Daten sind ein äusserst lukratives Ziel für Cyberkriminelle. Ein Angreifer muss nicht mühsam produktive Systeme knacken, wenn er einfach das Backup-Archiv kopieren kann, welches alle Daten des gesamten Unternehmens gebündelt enthält. Daher sind drastische Sicherheitsvorgaben unerlässlich:

- **Verschlüsselungspflicht:** Das Konzept schreibt vor, ab welcher Datenklassifizierung (z.B. "Streng Vertraulich" oder "Personenbezogen") die Daten auf den Backup-Medien im Ruhezustand (Data-at-Rest) zwingend verschlüsselt sein müssen (z.B. mittels AES-256).
- **Übertragungssicherheit:** Auch der Weg zum Backup-Speicher muss geschützt sein. Daten müssen bei der Netzwerkübertragung (Data-in-Transit) durch starke, aktuelle Protokolle wie TLS 1.3 kryptographisch abgesichert werden, um Man-in-the-Middle-Angriffe auszuschliessen.
- **Schlüsselverwaltung:** Die stärkste Verschlüsselung ist nutzlos, wenn der Schlüssel verloren

geht oder ungeschützt auf einem Server liegt. Das Konzept regelt die sichere Aufbewahrung, Rotation und die Notfallwiederherstellung von kryptographischen Schlüsseln (z.B. durch Hardware Security Modules - HSM).

- **Zugriffsregelung & Kontrolle:** Der Zugriff auf Backups muss streng nach dem "Need-to-Know"-Prinzip und dem Prinzip der minimalen Rechtevergabe erfolgen. Jeder einzelne Zugriff (lesend, schreibend, löschend) muss revisionssicher protokolliert (geloggt) und regelmässig auf Anomalien hin auditiert werden.

#### Praxisbeispiel:

Eine Schweizer Versicherung sichert ihre Kundendatenbank. Die Daten werden über eine **TLS-verschlüsselte** Verbindung ins Backup-Rechenzentrum übertragen (Übertragungssicherheit). Dort werden sie mit **AES-256 verschlüsselt** auf Festplatten abgelegt (Verschlüsselungspflicht). Der Zugang zum Backup-Server ist durch eine Zwei-Faktor-Authentifizierung (MFA) geschützt, und nur drei designierte Senior-Administratoren haben die Berechtigung, einen Restore anzustossen (**Zugriffsregelung**). Jeder Login dieser Administratoren wird in einem separaten, vor Manipulation geschützten Log-System verzeichnet (**Zugriffskontrolle**).

### 3.2 Aufbewahrungsvorgaben im Konzept (Folie 19)

Daten dürfen weder zu kurz noch unendlich lange gespeichert werden. Die Aufbewahrungsvorgaben bewegen sich im Spannungsfeld zwischen geschäftlichem Nutzen, Speicherkosten und zwingenden rechtlichen Restriktionen.

- **Aufbewahrungsfrist & Gesetzliche Pflichten:** Für jede Datenkategorie gibt es strikte Fristen. Im Schweizer Umfeld diktiert das Obligationenrecht (OR), insbesondere Art. 958f OR, dass Geschäftsbücher und Buchungsbelege zwingend 10 Jahre aufbewahrt werden müssen. Gleichzeitig verlangt das neue Schweizer Datenschutzgesetz (revDSG) die Löschung von Personendaten, sobald der Zweck ihrer Bearbeitung entfallen ist. Das Konzept muss diese Vorgaben in konkrete IT-Regeln übersetzen.
- **Archivklasse vs. Backup:** Das Konzept differenziert klar. Ein operatives Backup dient der Wiederherstellung bei einem Ausfall (kurze Retention, z.B. 30 Tage). Ein Langzeitarchiv dient der Erfüllung gesetzlicher Aufbewahrungspflichten (Retention z.B. 10 Jahre) und muss oft unveränderbar (WORM - Write Once Read Many) gestaltet sein.
- **Löschprozess & Nachweis:** Nach Ablauf der 10 Jahre (oder einer anderen Frist) dürfen die Daten nicht einfach vergessen werden. Sie müssen sicher, irreversibel und nachweisbar vernichtet werden (z.B. durch mehrfaches Überschreiben oder physisches Schreddern von Festplatten). Dieser Prozess muss für behördliche Audits dokumentiert werden.

#### Praxisbeispiel:

Ein Schweizer KMU im Maschinenbau generiert monatliche Rechnungen. Das operative IT-System zieht jede Nacht ein **Backup** für den Fall eines Serverabsturzes (Speicherdauer: 4 Wochen). Am Monatsende werden die PDF-Rechnungen und die zugehörigen Buchungsdaten

jedoch in eine separate **Archivklasse** verschoben. Diese Daten werden auf speziellen, nicht überschreibbaren Speichermedien für exakt 10 Jahre gesperrt abgelegt, um den **gesetzlichen Pflichten (OR)** zu genügen. Nach 10 Jahren und einem Tag greift ein automatisierter **Löschprozess**, der die Dateien forensisch sicher entfernt, um Platz zu sparen und datenschutzrechtliche Risiken zu minimieren. Ein Zertifikat über diese Löschung wird automatisch im **Nachweis**-System für die Wirtschaftsprüfer abgelegt.

### 3.3 Speicherortvorgaben (Folie 20)

In einer global vernetzten Cloud-Welt ist der physische Aufenthaltsort von Daten (Data Sovereignty) ein zentrales Compliance-Thema, das strikt reguliert werden muss.

- **Standortvorgaben & Datenlokalisierung:** Für sensible Daten, insbesondere solche mit Schweizer Datenschutzrelevanz (z.B. Gesundheitsdaten, Bankkundengeheimnis), schreibt das Konzept zwingend vor, dass die Speicherung ausschliesslich auf Servern erfolgen darf, die sich physisch auf Schweizer Staatsgebiet befinden. Dies schützt die Daten vor dem Zugriff ausländischer Behörden (z.B. US CLOUD Act).
- **Physische Sicherheit:** Die Gebäude, in denen sich die Backup-Server befinden, müssen strengen Normen entsprechen. Dies umfasst biometrischen Zutrittsschutz, Videoüberwachung, redundante Klimatisierung, Brandschutz (z.B. Stickstoff-Löschanlagen) und Schutz vor Naturgefahren.
- **Externe Lagerung & Medientyp:** Werden physische Medien (z.B. LTO-Magnetbänder) genutzt, müssen diese in einem feuerfesten Tresor an einem externen, weit entfernten Standort (Off-Site) gelagert werden. Der Transport dorthin muss durch zertifizierte Kuriere erfolgen und vertraglich wasserdicht geregelt sein.

#### Praxisbeispiel:

Eine Schweizer Privatbank nutzt für ihre primären Systeme ein hochsicheres Rechenzentrum in Zürich. Die **Standortvorgaben** des Konzepts verbieten ausdrücklich die Nutzung von Public-Cloud-Speichern im europäischen Ausland für Kundenstammdaten (**Datenlokalisierung**). Als Backup-Strategie wird ein dediziertes Bunker-Rechenzentrum in den Schweizer Alpen angemietet. Dieses Rechenzentrum ist durch bewaffnetes Personal und biometrische Schleusen gesichert (**Physische Sicherheit**). Einmal wöchentlich wird zudem ein stark verschlüsseltes Magnetband (**Medientyp**) durch ein gepanzertes Geldtransport-Unternehmen in einen Banktresor ausserhalb der IT-Räumlichkeiten gebracht (**Externe Lagerung**), um selbst bei der Zerstörung beider Rechenzentren ein finales "Air-Gapped" (physisch getrenntes) Backup zu besitzen.

### 3.4 Umsetzung und Kontrolle (Folie 21)

Das beste Konzept bleibt wirkungslos, wenn es in der Praxis nicht strikt angewandt und überwacht wird. Die operative Umsetzung erfordert rigores Management und

kontinuierliche Verifikation.

- **Konfigurationsstandard & Automatisierung:** IT-Systeme dürfen nicht manuell und nach dem Bauchgefühl einzelner Administratoren konfiguriert werden. Die Vorgaben aus dem Konzept werden in standardisierte Konfigurationsvorlagen übersetzt (z.B. Infrastructure as Code). Wo immer möglich, werden Sicherheitseinstellungen technisch erzwungen (Enforcement), sodass menschliche Fehlkonfigurationen von vornherein unmöglich gemacht werden.
- **Kontrollmechanismen:** Die IT-Umgebung ist hochdynamisch. Automatisierte Skripte und Compliance-Scanner müssen täglich prüfen, ob die Vorgaben (z.B. "Ist bei allen Backups die Verschlüsselung aktiviert?") im laufenden Betrieb noch eingehalten werden.
- **Ausnahmemanagement:** In der Realität kann es Situationen geben, in denen eine Vorgabe temporär nicht erfüllt werden kann (z.B. ein historisches Legacy-System, das keine moderne Verschlüsselung unterstützt). Solche Abweichungen dürfen nicht verschwiegen werden, sondern müssen durch ein formelles Ausnahmemanagement (Risk Acceptance) durch das Management dokumentiert, zeitlich befristet genehmigt und regelmässig reevaluiert werden.
- **Auditfähigkeit:** Jede Konfigurationsänderung, jede gewährte Ausnahme und jede sicherheitsrelevante Aktion muss in unveränderlichen Audit-Logs gespeichert werden. Interne (z.B. CISO) und externe (z.B. FINMA, Wirtschaftsprüfer) Auditoren müssen die Compliance jederzeit lückenlos nachvollziehen können.

#### Praxisbeispiel:

Ein multinationales Pharmaunternehmen mit Hauptsitz in Basel rollt eine neue Backup-Infrastruktur aus. Die Konfiguration der Backup-Jobs erfolgt nicht per Klick in einer Benutzeroberfläche, sondern vollautomatisiert über Skripte (**Automatisierung**). Ein **Kontrollmechanismus** (ein sogenanntes Cloud Security Posture Management Tool) scannt stündlich alle Speichersysteme. Wird festgestellt, dass ein Entwickler versehentlich einen Speicher-Bucket (Speicherort) ohne TLS-Zwang erstellt hat, wird dieser sofort automatisch blockiert und ein Ticket an das Security-Team gesendet. Ein uralter Produktionssteuerungsrechner, der kein TLS 1.3 kann, erhält einen formellen **Ausnahmeantrag**, der vom Risikomanager für genau 6 Monate bewilligt wird, bis die Maschine ausgetauscht ist. Alle diese Prozesse und Bewilligungen werden in einem IT-Service-Management-Tool fälschungssicher dokumentiert, sodass der externe Wirtschaftsprüfer im Folgejahr die lückenlose Umsetzung des Konzepts attestieren kann (**Auditfähigkeit**).

## 4. Synthese und kritische Würdigung

Die detaillierte Analyse der von Mevluet Polat dargelegten Folien zeigt auf, dass ein robustes Datenhaltungskonzept eine untrennbare Symbiose aus Hochverfügbarkeitsarchitekturen und rigorosen Sicherheitsmassnahmen darstellt. Die in Hauptkategorie 5 beschriebenen Vorgaben

zur Sicherheit (Verschlüsselung, Zugriffskontrolle) dürfen die in den Folien 14 bis 17 definierten Verfügbarkeitsziele (RTO, Clustering, SLAs) nicht untergraben, sondern müssen diese ergänzen.

Ein hochverfügbares System, das jedoch unverschlüsselt und für jedermann zugänglich ist, stellt ein katastrophales Risiko dar. Umgekehrt ist ein perfekt verschlüsseltes System, das nach einem Ausfall aufgrund komplexer Schlüsselverwaltungsfehler nicht innerhalb der RTO wiederhergestellt werden kann, in der betrieblichen Praxis wertlos.

Die wahre Herausforderung in der modernen IT-Governance liegt folglich in der konsequenten und auditiertensicheren Orchestrierung dieser sich teils widersprechenden Anforderungen. Die strikte Definition von Klassen, Fristen und Standorten, gekoppelt mit kontinuierlichem Monitoring und automatisierten Kontrollmechanismen, bildet das zwingende Fundament, auf dem zukunftsfähige, resiliente und gesetzeskonforme Unternehmens-IT aufbaut. Die Einbettung in Schweizer Spezifika (OR, DSG, physische Datensouveränität) macht diese Vorgaben nicht nur zu Best Practices, sondern zu rechtlich bindenden Imperativen für das Überleben im digitalen Zeitalter.

## 5. Fazit

Die vorliegende Ausarbeitung der Richtlinien und Parameter für Verfügbarkeit, Sicherheit und Datenaufbewahrung belegt eindrücklich die Komplexität des modernen IT-Managements. Die Kategorisierung von Verfügbarkeitsklassen, die Festlegung harter RTO-Werte und deren Überwachung mittels SLAs sind unverzichtbare Instrumente zur Sicherstellung der Business Continuity. Flankiert werden diese Massnahmen zwingend durch kompromisslose Sicherheitsarchitekturen, die Kryptographie, strenge Zugriffsregelungen und gesetzeskonforme, geolokalisierte Aufbewahrungsstrategien umfassen. Letztendlich entfalten diese konzeptionellen Vorgaben ihre volle Wirkung nur durch eine konsequente, idealerweise automatisierte Umsetzung und eine permanente, auditsichere Kontrolle. Organisationen, die diese verbindlichen Standards tief in ihrer betrieblichen DNA verankern, minimieren nicht nur ihre operativen und juristischen Risiken, sondern schaffen ein signifikantes Mass an Vertrauen bei Kunden, Partnern und Regulatoren.

## Quellenverzeichnis

1. **Polat, M.** (o.D.). *Verbindliche Vorgaben – Verfügbarkeit* (Folien 14-17). Internes Datenhaltungskonzept / Präsentationsmaterial.
2. **Polat, M.** (o.D.). *Verbindliche Vorgaben – Sicherheit und Aufbewahrung* (Folien 18-21). Internes Datenhaltungskonzept / Präsentationsmaterial.
3. **Bundesversammlung der Schweizerischen Eidgenossenschaft.** *Obligationenrecht (OR)*, insbesondere Art. 958f (Aufbewahrung der Geschäftsbücher). Bern, Schweiz.
4. **Bundesversammlung der Schweizerischen Eidgenossenschaft.** *Bundesgesetz über den*

*Datenschutz (DSG), inklusive Revision (revDSG). Bern, Schweiz.*

5. **International Organization for Standardization (ISO).** *ISO/IEC 27001: Information security management.* Genf, Schweiz. (Allgemeine Referenz zu Informationssicherheits-  
Managementsystemen und CIA-Triade).
6. **ITIL (IT Infrastructure Library).** *Service Design & Service Operation Guidelines.* (Allgemeine Referenz zu Service Level Agreements, RTO, RPO und IT-Verfügbarkeitsmanagement).